LABCONTROL 4.0

RELATÓRIO TÉCNICO DE AVALIAÇÃO DE VULNERABILIDADES E PENTEST

FACULDADE DE TECNOLOGIA SENAI (UniSENAI - Sorocaba)

Curso Superior de Tecnologia em Análise e Desenvolvimento de Sistemas (CST ADS)

Projeto Integrador IV (PI-IV) — 4º Semestre / 2026

Integrantes da Equipe:

Giovani Miamoto | Victor Geroto | Carlos Eduardo Oliveira | André Fernandes | Gustavo Silveira

Responsável Técnico da Avaliação: Giovani Miamoto (@giovanimiamotob)

Repositório do Projeto: github.com/labControl4-0

Data de Conclusão: Novembro / 2026

Seção 1: Introdução e Justificativa

O **LabControl 4.0** é uma solução de telemetria industrial em tempo real e monitoramento de ativos que integra sensores físicos de chão de fábrica (protocolo MQTT), orquestração de mensageria (Eclipse Mosquitto), APIs de backend (Spring Boot e .NET Core com persistência PostgreSQL), interfaces operacionais para smartphones (React Native / Expo com fila offline SQLite) e portal web de visualização da planta baixa fabril (React 18 / Tailwind CSS).

A convergência entre Tecnologia da Informação (TI) e Tecnologia da Operação (TO) amplifica a superfície de ataque em plantas industriais. Vulnerabilidades cibernéticas nesse contexto colocam em risco não apenas a confidencialidade de dados cadastrais, mas a integridade operacional de máquinas pesadas (prensas, tornos CNC e células robóticas). A manipulação de telemetria por atores maliciosos pode acarretar paradas não planejadas de produção, quebras mecânicas catastróficas e severos riscos à integridade física de operadores de fábrica. Este relatório técnico consolida os testes práticos de segurança ofensiva e defensiva realizados no sistema.

Seção 2: Objetivos e Escopo da Avaliação

2.1 Objetivos

- Executar varredura automatizada autenticada contra as interfaces e rotas REST da aplicação.
- Realizar a exploração prática controlada (*Proof of Concept*) de duas vulnerabilidades críticas confirmadas.
- Documentar as causas raízes, impactos no negócio fabril e validar a mitigação efetiva através de retestes comparativos.

2.2 Escopo Abrangido e Exclusões

Partes Avaliadas: Endpoints da API REST (autenticação JWT, ativos, telemetria e sincronização), interfaces web e mobile, e configurações Docker Compose.

Exclusões Justificadas: Sensores físicos em linha de produção (substituídos por simuladores reproduzíveis Node-RED) e ataques de negação de serviço volumétricos de infraestrutura externa (DDoS volumétrico L3/L4).

Seção 3: Metodologia e Ambiente de Testes

A avaliação seguiu o padrão internacional **OWASP Web Security Testing Guide (WSTG v4.2)**:

1. **Varredura Automatizada (DAST):** OWASP ZAP (Zed Attack Proxy) v2.15.0 com script de autenticação via Bearer Token JWT e varredura ativa/passiva completa.
2. **Auditoria Estática de Dependências (SAST):** `npm audit` nos módulos web e mobile, além de verificação automatizada de segredos no pipeline do GitHub Actions.
3. **Ambiente de Homologação:** Rede Docker compartilhada `labcontrol-network` com PostgreSQL, API Spring Boot e simulador de telemetria operando com dados sintéticos.

Seção 4: Resultados da Avaliação

4.1 Resumo dos Achados da Varredura Automatizada

Código	Endpoint / Componente	Vulnerabilidade (CWE)	Risco	Status da Triagem
SEC-01	`GET /api/v1/machines/{id}`	BOLA / IDOR (CWE-639)	ALTO	Confirmado (Verdadeiro Positivo)
SEC-02	`GET /api/v1/telemetry/recent`	Ausência de Rate Limiting (CWE-799)	MÉDIO	Confirmado (Verdadeiro Positivo)
SEC-03	`POST /api/v1/auth/login`	Ausência de Header HSTS	BAIXO	Falso Positivo em Homologação Local
SEC-04	`GET /api/v1/alerts`	Exposição de Stack Trace em Erro (CWE-209)	MÉDIO	Confirmado (Verdadeiro Positivo)
SEC-05	`POST /api/v1/sync`	Ausência de Idempotência / Replay (CWE-294)	MÉDIO	Confirmado (Verdadeiro Positivo)

4.2 Exploração Controlada das Duas Vulnerabilidades Confirmadas

Exploração 1: BOLA / IDOR em Ativos Industriais Restritos (CWE-639)

Um operador com permissão estrita para máquinas do Setor de Usinagem A manipulou o parâmetro sequencial `{id}` na requisição REST e conseguiu obter informações completas de um ativo do Setor Restrito B:

```
# Chamada ofensiva simulada via curl
curl -X GET "http://localhost:8080/api/v1/machines/42" \
     -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsIn..."

# Resposta obtida (Vulnerável):
```

```
HTTP/1.1 200 OK
{
  "id": 42,
  "name": "Laser-Cutter-Industrial-X1",
  "sector": "Setor-B-Confidencial",
  "criticality": "ALTA"
}
```

Impacto: Quebra de segregação de funções industriais e vazamento de ativos sensíveis.

Exploração 2: Esgotamento de Recursos por Falta de Rate Limiting (CWE-799)

Disparo concorrente de 120 requisições simultâneas em 5 segundos contra o endpoint de telemetria sem qualquer limitação de taxa:

```
seq 1 120 | xargs -n 1 -P 10 curl -s -o /dev/null -w "%{http_code}\n" \
  "http://localhost:8080/api/v1/telemetry/recent?machineId=1" -H "Authorization: Bearer ey..."
```

Impacto: Todas as 120 requisições retornaram HTTP 200. O tempo de resposta da API saltou de 45 ms para 2.800 ms e o pool de conexões do PostgreSQL foi sobrecarregado, atrasando alertas industriais para os operadores.

Seção 5: Discussão das Causas, Impactos e Mitigações

Achado	Causa Raiz Técnica	Mitigação e Código Implementado	Resultado do Reteste
BOLA (SEC-01)	Consulta ao repositório SQL sem checar setor do token JWT.	Anotação `@PreAuthorize("@securityService.canAccessMachine(auth, #id)")`.	**HTTP 403 Forbidden** confirmado no reteste.
Rate Limit (SEC-02)	Ausência de middleware de controle de vazão.	Implementação de Token Bucket limitando a 60 req/min por token.	**HTTP 429 Too Many Requests** após 60 requisições.
Stack Trace (SEC-04)	Exceções não tratadas retornando corpo default.	Global Exception Handler retornando JSON sanitizado com `correlation_id`.	**HTTP 400 Bad Request** limpo sem dados internos.
Replay Sync (SEC-05)	Processamento cego de lotes sem chave de transação.	Validação obrigatória de cabeçalho `X-Idempotency-Key`.	**HTTP 200 ALREADY_PROCESSED** sem duplicidades.

Seção 6: Conclusões, Nível de Segurança e Lições Aprendidas

A avaliação de cibersegurança do LabControl 4.0 demonstrou maturidade técnica na estruturação da infraestrutura Docker e na persistência via ORM (sem injeções SQL). As quatro vulnerabilidades identificadas foram completamente sanadas através de código defensivo e validações de reteste. Como recomendação de continuidade para o próximo semestre, sugere-se a implementação de TLS mútuo (mTLS) no tráfego MQTT entre sensores e broker.

Seção 7: Referências Bibliográficas (Padrão ABNT)

1. OWASP FOUNDATION. **OWASP Top 10 Web Application Security Risks**. 2021. Disponível em: <https://owasp.org/Top10/>.
2. OWASP FOUNDATION. **OWASP API Security Top 10**. 2023. Disponível em: <https://owasp.org/API-Security/>.
3. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **NBR IEC 62443: Redes de comunicação industriais - Segurança de rede e de sistemas**. Rio de Janeiro: ABNT, 2020.

4. NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **NIST SP 800-115: Technical Guide to Information Security Testing and Assessment**. Gaithersburg: NIST, 2008.
5. BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.

Relatório emitido pela Equipe do Projeto Integrador IV — UniSENAI Sorocaba — Novembro / 2026.